

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA SICUREZZA DEI SISTEMI INFORMATIVI

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO016_00	00	12/04/2026	10
Redatto da	Approvato da	Classificazione	Stato
IT / RSGI	AD – Francesco Epifani	Riservato	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
30/04/2026	30/04/2026	30/04/2026

Sommario

1. Scopo e campo di applicazione.....	3
2. Riferimenti normativi.....	3
3. Architettura del sistema informativo TD.....	3
4. Inventario degli asset e mappa applicativa.....	4
5. Gestione degli accessi e delle identità.....	5
5.1 Autenticazione e autorizzazione.....	5
5.2 Gestione del ciclo di vita delle utenze.....	5
6. Sicurezza delle postazioni di lavoro.....	5
7. Sicurezza della rete e delle comunicazioni.....	6
8. Sicurezza dei sistemi cloud e dei fornitori SaaS.....	6
9. Protezione dei dati sanitari e privacy.....	7
10. Business continuity e disaster recovery.....	7
11. Gestione degli incidenti di sicurezza informatica.....	8
12. Formazione e sensibilizzazione.....	8
13. Audit e monitoraggio.....	9
14. Matrice delle responsabilità (RACI).....	9
15. Indicatori di processo.....	9
16. Storico delle revisioni.....	10

1. Scopo e campo di applicazione

La presente procedura disciplina la sicurezza delle informazioni, dei sistemi informativi e dell'infrastruttura tecnologica di Toscana Diagnostica, in conformità alla ISO 27001:2022, al Regolamento UE 2016/679 (GDPR) e alla normativa italiana in materia di protezione dei dati personali. La strategia tecnologica di Toscana Diagnostica è fondata sul paradigma cloud-first: tutti i sistemi applicativi core operano in modalità Software as a Service (SaaS), con disaster recovery assicurato dai rispettivi fornitori. L'infrastruttura di rete è gestita da un partner tecnologico dedicato.

La procedura si applica a tutte le sedi operative, a tutti i sistemi informativi (clinici, amministrativi, di comunicazione), a tutto il personale (dipendenti, collaboratori, consulenti) e ai fornitori che accedono ai dati o ai sistemi di Toscana Diagnostica.

2. Riferimenti normativi

Norma / Riferimento	Ambito
ISO 27001:2022	Sistemi di gestione per la sicurezza delle informazioni: requisiti
ISO 27002:2022	Controlli per la sicurezza delle informazioni: linee guida
ISO 27017:2015	Controlli di sicurezza per i servizi cloud
ISO 27018:2019	Protezione dei dati personali nei cloud pubblici
Reg. UE 2016/679 (GDPR)	Protezione dei dati personali: principi, diritti, obblighi, data breach
D.Lgs. 196/2003 (Codice Privacy)	Codice in materia di protezione dei dati personali, come modificato dal D.Lgs. 101/2018
D.Lgs. 138/2024 (NIS 2)	Recepimento Direttiva UE 2022/2555: misure di sicurezza informatica per soggetti essenziali e importanti
Provvedimento Garante 27/11/2008	Misure e accorgimenti per gli amministratori di sistema
AgID – Misure minime ICT per le PA	Riferimento di best practice per le misure di sicurezza ICT (applicabile per analogia)
TD-SGI-POL001	Politica Integrata del SGI
TD-SGI-PRO015	Procedura Gestione Rischio Clinico (interfaccia IT-clinica)

3. Architettura del sistema informativo TD

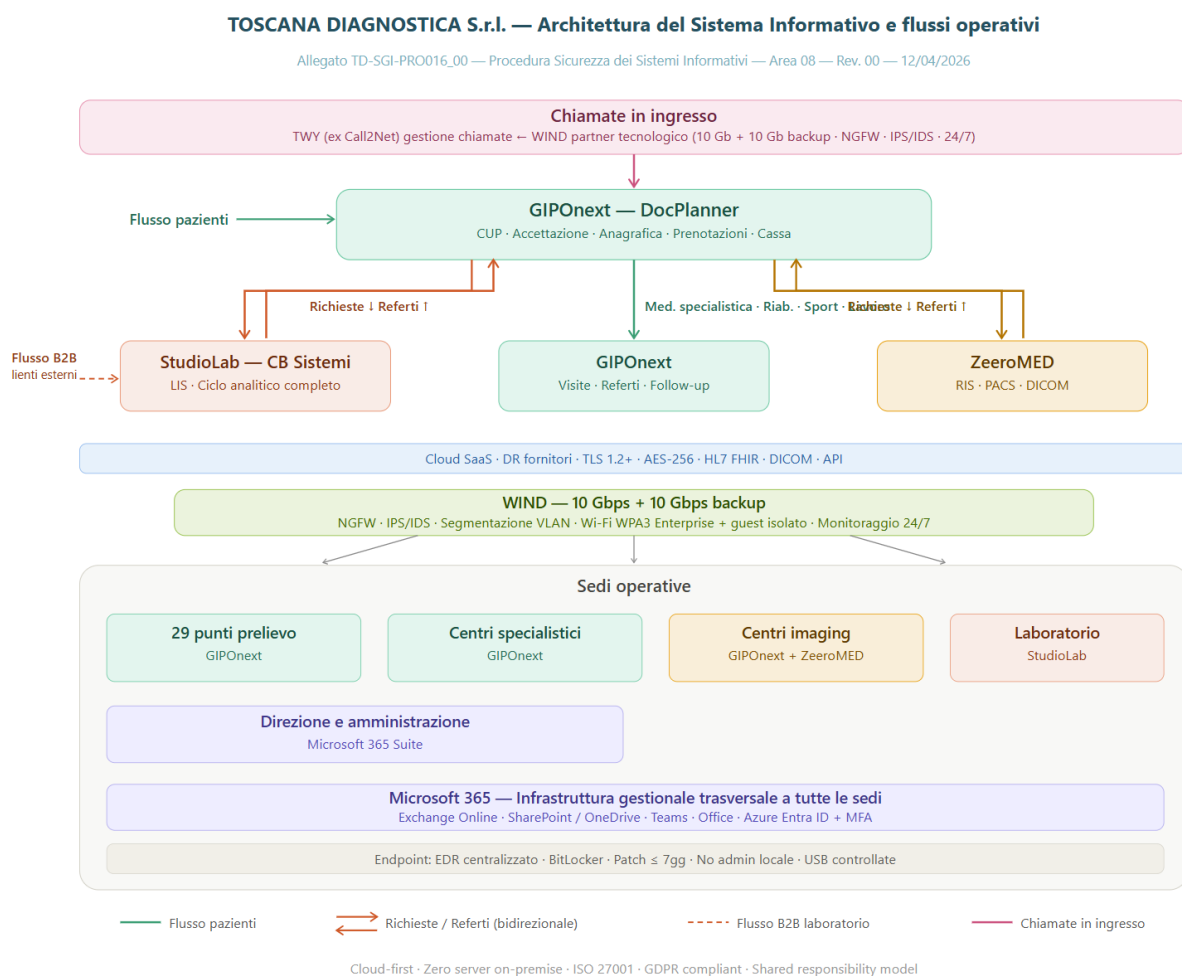
Toscana Diagnostica opera con un'architettura interamente cloud-based. I sistemi sono erogati in modalità SaaS dai rispettivi fornitori qualificati, con connettività garantita dal partner tecnologico WIND. L'architettura è progettata per garantire alta disponibilità, scalabilità, sicurezza dei dati e continuità operativa senza necessità di un datacenter locale.

Sistema / Servizio	Fornitore	Modalità	Funzione
Microsoft 365 Suite	Microsoft	Cloud SaaS (Azure EU)	Posta elettronica (Exchange Online), storage documentale (SharePoint/OneDrive), collaborazione (Teams), office automation
GIPOnext	DocPlanner	Cloud SaaS	CUP e accettazione pazienti, anagrafica, prenotazioni, gestione amministrativa del paziente
StudioLab	CB Sistemi	Cloud SaaS	LIS – Laboratory Information System: gestione del ciclo analitico completo dalla preanalitica alla refertazione
ZeeroMED	ZeeroMED	Cloud SaaS	RIS – Radiology Information System e PACS – Picture Archiving and Communication System. Gestione imaging diagnostico, archiviazione DICOM
Rete dati e connettività	WIND	Linea dedicata 10 Gb + backup	Connessione Internet e accesso ai

		10 Gb	servizi cloud per tutte le sedi operative a gestione diretta
Fonia VoIP	TWY (ex Call2Net)	Cloud / Hosted PBX	Centralino virtuale, telefonia IP, numerazioni, IVR, instradamento chiamate

L'assenza di server fisici on-premise riduce drasticamente la superficie di attacco locale, semplifica la manutenzione e delega la sicurezza infrastrutturale (patching, hardening, ridondanza, backup) ai fornitori SaaS, che operano su datacenter certificati ISO 27001 e conformi al GDPR.

Graficamente:



4. Inventario degli asset e mappa applicativa

L'IT mantiene un inventario aggiornato degli asset informatici della rete TD, classificati per tipologia:

- Postazioni di lavoro (PC desktop, laptop) e monitor: inventario con numero seriale, modello, sistema operativo, data di acquisto, sede di assegnazione, utente assegnatario.
- Dispositivi medicali connessi: analizzatori di laboratorio interfacciati con StudioLab, modalità DICOM (RX, TC, RM, mammografo, ecografi) interfacciate con ZeeroMED, lettori barcode, stampanti referti.
- Dispositivi di rete: firewall, switch, access point Wi-Fi, router. Manutenzione e configurazione a carico del partner WIND.

- Periferiche: stampanti, scanner, lettori di tessera sanitaria, dispositivi di firma digitale.
- Dispositivi mobili: eventuali tablet o smartphone aziendali utilizzati in ambito diagnostico.
- Licenze software: inventario delle licenze Microsoft 365, antivirus/endpoint protection, software di produttività, licenze diagnostiche.

L'inventario è aggiornato in occasione di ogni acquisto, dismissione, spostamento o assegnazione, e riesaminato almeno annualmente.

5. Gestione degli accessi e delle identità

5.1 Autenticazione e autorizzazione

L'accesso a tutti i sistemi informativi è protetto da autenticazione individuale. Ogni utente dispone di credenziali personali e non trasferibili. Le regole di autenticazione sono:

- Microsoft 365: autenticazione tramite Azure Active Directory (Entra ID) con MFA (Multi-Factor Authentication) obbligatoria per tutti gli utenti. Password con requisiti di complessità (almeno 12 caratteri, maiuscole, minuscole, numeri, simboli) e scadenza ogni 90 giorni.
- GIPOnext, StudioLab, ZeeroMED: autenticazione con credenziali dedicate per ciascun sistema; ove tecnicamente possibile, integrazione con SSO (Single Sign-On) tramite Azure AD. MFA raccomandata e attivata dove disponibile.
- Accesso VPN: per eventuali connessioni remote (manutenzione, assistenza), utilizzo di VPN con autenticazione forte (certificato + password).
- Profilazione basata sul ruolo (RBAC): ogni utente accede esclusivamente alle funzioni e ai dati necessari per lo svolgimento della propria mansione. I profili di accesso sono definiti dall'IT in collaborazione con i responsabili di area e approvati dall'RSGL.

5.2 Gestione del ciclo di vita delle utenze

Il ciclo di vita delle utenze segue un processo controllato:

- Attivazione: alla firma del contratto, People & Culture comunica all'IT i dati del nuovo utente. L'IT crea le utenze sui sistemi necessari con il profilo di accesso coerente con la mansione, entro il primo giorno di lavoro.
- Modifica: in caso di cambio di mansione, sede o responsabilità, i profili di accesso sono aggiornati entro 5 giorni lavorativi dalla comunicazione.
- Disattivazione: alla cessazione del rapporto di lavoro, People & Culture comunica all'IT con almeno 24 ore di anticipo. Tutte le utenze sono disattivate entro la fine dell'ultimo giorno di lavoro. I dati personali dell'utente cessato sono conservati secondo le policy di retention e successivamente cancellati.
- Revisione periodica: l'IT effettua una revisione completa delle utenze attive con cadenza semestrale, verificando la coerenza tra utenze e personale effettivamente in servizio, e la conformità dei profili di accesso.

6. Sicurezza delle postazioni di lavoro

Le postazioni di lavoro (desktop e laptop) sono configurate e gestite secondo le seguenti regole:

- Sistema operativo: Windows 10/11 Professional o superiore, con aggiornamenti automatici attivati. Le patch di sicurezza sono applicate entro 7 giorni dal rilascio.

- Endpoint protection: soluzione antivirus/antimalware enterprise con aggiornamento automatico delle firme, protezione in tempo reale, scansione programmata settimanale, EDR (Endpoint Detection and Response) centralizzato.
- Cifratura disco: BitLocker attivato su tutti i laptop. I desktop in aree accessibili al pubblico hanno cifratura attivata.
- Blocco schermo automatico: dopo 5 minuti di inattività. Sblocco con credenziali.
- Divieto di installazione software: gli utenti non dispongono di privilegi di amministratore locale. L'installazione di software è riservata all'IT.
- Periferiche rimovibili: l'utilizzo di chiavette USB è limitato alle operazioni autorizzate dall'IT. I dispositivi rimovibili sono sottoposti a scansione antivirus automatica all'inserimento.
- Navigazione Internet: filtro contenuti attivo con blocco delle categorie a rischio (malware, phishing, contenuti inappropriati). Logging della navigazione per indagini di sicurezza.
- Posta elettronica: filtro antispam e antiphishing attivo su Exchange Online. Allegati potenzialmente pericolosi (.exe, .bat, .ps1, .vbs) bloccati. Safe Attachments e Safe Links di Microsoft Defender for Office 365 attivi.

7. Sicurezza della rete e delle comunicazioni

L'infrastruttura di rete è progettata e gestita dal partner tecnologico WIND, con le seguenti caratteristiche di sicurezza:

- Connettività: linea dedicata 10 Gbps con backup automatico a 10 Gbps su tutte le sedi operative a gestione diretta. Il failover è automatico e garantisce la continuità dell'accesso ai servizi cloud.
- Firewall perimetrale: next-generation firewall (NGFW) con IPS/IDS (Intrusion Prevention/Detection System), application control, web filtering, protezione DDoS.
- Segmentazione di rete: la rete è segmentata in VLAN distinte per: rete clinica (postazioni diagnostiche, analizzatori, modalità DICOM), rete amministrativa, rete ospiti/pazienti (Wi-Fi segregato), rete di gestione (management).
- Wi-Fi: reti wireless separate (SSID distinti) per il personale (con autenticazione 802.1X/WPA3 Enterprise) e per gli ospiti (captive portal, isolamento, banda limitata). Nessun accesso dalla rete ospiti alla rete clinica o amministrativa.
- Fonia VoIP: il servizio di telefonia è gestito dal centralino hosted di TWY (ex Call2Net), con traffico voce su rete IP dedicata (QoS), cifratura delle comunicazioni (SRTP), registrazione delle chiamate ove previsto dalla normativa.
- Monitoraggio: il partner WIND effettua il monitoraggio continuo (24/7) dello stato della connettività e delle prestazioni di rete, con notifica automatica degli allarmi all'IT di Toscana Diagnostica.

8. Sicurezza dei sistemi cloud e dei fornitori SaaS

La sicurezza dei sistemi cloud è un elemento critico dell'architettura di Toscana Diagnostica. La responsabilità è condivisa (shared responsibility model) tra TD e i fornitori SaaS:

Responsabilità	Fornitore SaaS	Toscana Diagnostica
Infrastruttura fisica (datacenter, server, rete)	Responsabile	Non applicabile
Sicurezza della piattaforma (OS, patching, hardening)	Responsabile	Monitoraggio SLA
Backup e disaster recovery	Responsabile (contrattuale)	Verifica periodica RPO/RTO
Disponibilità del servizio (uptime)	Responsabile (SLA)	Monitoraggio e escalation

Gestione degli accessi applicativi	Cooperazione	Responsabile (utenze, RBAC)
Protezione dei dati (encryption at rest e in transit)	Responsabile (piattaforma)	Verifica contrattuale
Configurazione di sicurezza applicativa	Cooperazione	Responsabile (impostazioni)
Conformità GDPR e data residency	Responsabile (DPA)	Responsabile (nomina, verifica)

Per ciascun fornitore SaaS, Toscana Diagnostica verifica e mantiene: il contratto di servizio con SLA definiti (uptime, tempi di risposta, supporto); il Data Processing Agreement (DPA) ai sensi dell'art. 28 GDPR con garanzia di data residency in UE; le certificazioni di sicurezza del fornitore (ISO 27001, SOC 2, CSA STAR); la policy di backup e i parametri RPO (Recovery Point Objective) e RTO (Recovery Time Objective); la reportistica periodica sugli incidenti di sicurezza. La verifica è effettuata annualmente e in occasione di ogni rinnovo contrattuale, in coordinamento con la Due Diligence (TD-SGI-PRO006).

9. Protezione dei dati sanitari e privacy

I dati trattati da Toscana Diagnostica comprendono dati sanitari (categorie particolari ex art. 9 GDPR) e dati identificativi dei pazienti. Le misure di protezione includono:

- Cifratura dei dati: tutti i sistemi SaaS garantiscono cifratura dei dati at-rest (AES-256) e in-transit (TLS 1.2+). La posta elettronica su Microsoft 365 è protetta da TLS e, per comunicazioni sensibili, da cifratura end-to-end (OME).
- Minimizzazione dei dati: i sistemi sono configurati per raccogliere solo i dati necessari alla finalità del trattamento. L'accesso ai dati sanitari è limitato al personale sanitario e tecnico con necessità operativa.
- Pseudonimizzazione: ove possibile, i dati sono pseudonimizzati nei sistemi di analytics e di ricerca.
- Retention e cancellazione: le policy di conservazione sono definite per ciascuna tipologia di dato (referti di laboratorio 10 anni, immagini DICOM secondo normativa regionale, dati amministrativi 10 anni). Alla scadenza, i dati sono cancellati in modo sicuro.
- Data breach: in caso di violazione dei dati personali, è attivata la procedura di gestione degli incidenti (Sezione 11) con notifica al Garante entro 72 ore e comunicazione agli interessati se prevista dal GDPR.
- Diritti degli interessati: i diritti di accesso, rettifica, cancellazione, portabilità e opposizione sono garantiti attraverso un processo gestito dal DPO in collaborazione con l'IT.

10. Business continuity e disaster recovery

La strategia di business continuity e disaster recovery (BC/DR) di Toscana Diagnostica si fonda sul modello cloud-first: la responsabilità del disaster recovery infrastrutturale è in capo ai fornitori SaaS, ciascuno dei quali garantisce contrattualmente parametri di RPO e RTO.

Sistema	RPO	RTO	Backup	DR Provider
Microsoft 365	Quasi-zero (replica continua)	< 1 ora	Nativo Azure geo-ridondante	Microsoft (Azure EU)
GIPOnext	< 1 ora	< 4 ore	Backup giornaliero cloud	DocPlanner
StudioLab	< 1 ora	< 4 ore	Backup giornaliero cloud	CB Sistemi
ZeeroMED	< 1 ora	< 4 ore	Backup giornaliero +	ZeeroMED

			DICOM archive	
Rete WIND	N/A	Failover automatico (< 30 sec)	N/A	WIND (backup 10 Gb)
Fonia TWY	N/A	< 2 ore	Configurazioni su cloud	TWY

Toscana Diagnostica mantiene un Business Continuity Plan (BCP) che prevede: le procedure operative in caso di indisponibilità prolungata di ciascun sistema (procedure manuali di fallback, comunicazione al personale); i contatti di emergenza dei fornitori SaaS e del partner WIND; il test annuale di ripristino per ciascun sistema critico (LIS, RIS/PACS, GIPOnext); la comunicazione ai pazienti in caso di disservizio prolungato.

11. Gestione degli incidenti di sicurezza informatica

Un incidente di sicurezza informatica è qualsiasi evento che compromette la riservatezza, l'integrità o la disponibilità dei dati o dei sistemi. La gestione segue le fasi:

- Rilevazione e segnalazione: qualsiasi anomalia (comportamento sospetto del sistema, email di phishing ricevuta, sospetto accesso non autorizzato) è segnalata immediatamente all'IT. L'IT effettua il triage e classifica l'evento (basso, medio, alto, critico).
- Contenimento: l'IT attiva le misure di contenimento (isolamento della postazione, blocco dell'utenza compromessa, revoca degli accessi, comunicazione ai fornitori SaaS).
- Analisi e ripristino: indagine sull'origine e sull'estensione dell'incidente, in collaborazione con i fornitori SaaS. Ripristino dei sistemi e dei dati dal backup, se necessario.
- Notifica: se l'incidente configura un data breach (violazione dei dati personali), il DPO è informato immediatamente. Notifica al Garante entro 72 ore dalla scoperta (art. 33 GDPR). Comunicazione agli interessati se il rischio è elevato (art. 34 GDPR). Segnalazione al CSIRT nazionale se applicabile (D.Lgs. 138/2024, NIS 2).
- Documentazione e lesson learned: l'incidente è documentato nel Registro degli Incidenti Informatici con: cronologia, causa, impatto, azioni intraprese, raccomandazioni. Il rapporto è presentato al Riesame della Direzione.

12. Formazione e sensibilizzazione

La formazione sulla sicurezza informatica è obbligatoria per tutto il personale:

- Formazione iniziale (nell'ambito dell'induction, 2 ore): uso corretto delle credenziali, riconoscimento del phishing, protezione dei dati sanitari, regole di utilizzo delle postazioni, segnalazione degli incidenti.
- Aggiornamento annuale (1 ora): trend delle minacce, casi di phishing reali (anonimizzati), aggiornamenti normativi, buone pratiche.
- Simulazioni di phishing: l'IT conduce almeno 2 campagne annuali di phishing simulato per misurare la consapevolezza del personale e identificare le aree di miglioramento.
- Formazione per gli amministratori di sistema (4 ore, annuale): gestione sicura dei sistemi, logging, incident response, conformità al Provvedimento Garante sugli amministratori di sistema.

13. Audit e monitoraggio

L'IT conduce le seguenti attività di audit e monitoraggio:

- Logging: tutti gli accessi ai sistemi clinici (LIS, RIS/PACS, GIPOnext) e alla posta elettronica sono tracciati con log di accesso (utente, timestamp, azione). I log sono conservati per almeno 6 mesi e protetti da manomissione.
- Revisione dei log degli amministratori di sistema: con cadenza almeno annuale, in conformità al Provvedimento Garante 27/11/2008.
- Vulnerability assessment: scansione annuale delle vulnerabilità delle postazioni e della rete, condotta dall'IT o da un fornitore specializzato.
- Audit interno ISO 27001: nell'ambito del programma di audit del SGI, con cadenza annuale.
- Verifica dei fornitori SaaS: revisione annuale delle certificazioni, degli SLA, dei rapporti di incidente e delle misure di sicurezza dichiarate.

14. Matrice delle responsabilità (RACI)

R = Responsabile, A = Approvatore, C = Consultato, I = Informato.

Attività	IT	RSGI	P&C	Fornit.	DPO	AD
Inventario asset	R	I	I	–	I	I
Gestione utenze (creazione/revoca)	R	I	C	–	I	I
Configurazione sicurezza postazioni	R	I	I	–	I	I
Sicurezza rete e firewall	C	I	I	R	I	I
Verifica sicurezza fornitori SaaS	R	C	I	C	C	I
Gestione incidenti informatici	R	C	I	C	C	A
Notifica data breach (GDPR)	C	C	I	I	R	A
Formazione sicurezza IT	R	C	C	–	I	I
Audit e vulnerability assessment	R	C	I	C	I	I
Business continuity / DR test	R	C	I	R	I	A

15. Indicatori di processo

Uptime dei sistemi critici (LIS, RIS/PACS, GIPOnext): percentuale di disponibilità mensile. Obiettivo: ≥ 99,5%.

Tempo di ripristino effettivo (RTO reale): misurato durante i test annuali di DR. Obiettivo: entro i limiti contrattuali.

Incidenti di sicurezza classificati (medio/alto/critico): numero per trimestre. Obiettivo: riduzione progressiva.

Percentuale di utenze con MFA attiva: su Microsoft 365. Obiettivo: 100%.

Patch di sicurezza applicate nei termini (7 gg): percentuale. Obiettivo: ≥ 95%.

Tasso di click su phishing simulato: percentuale del personale che clicca. Obiettivo: ≤ 5%.

Revisione utenze completata nei termini (semestrale): conformità. Obiettivo: 100%.

Data breach notificati al Garante: numero. Obiettivo: zero.

Test DR completati nell'anno: numero di test per sistema critico. Obiettivo: almeno 1/sistema/anno.

Formazione sicurezza IT erogata: percentuale del personale formato nell'anno. Obiettivo: 100%.

16. Storico delle revisioni

Rev.	Data	Descrizione modifiche	Approvazione
------	------	-----------------------	--------------

00	12/04/2026	Prima emissione	Francesco Epifani
----	------------	-----------------	-------------------